

ПРАКТИЧЕСКАЯ РАБОТА № 16.1

Тема: Межсетевой экран. Настройка межсетевого экрана.

Программное обеспечение:

1. Cisco Packet Tracer и соответствующий дамп, расположенный <https://drive.google.com/drive/folders/1HWu1eVC9yvVkj1L5YfBuqkB7kqB5epHK?usp=sharing>

Вопросы для обсуждения:

1. Что такое межсетевой экран (firewall)?
2. Какие типы межсетевых экранов существуют?
3. Чем отличается пакетный фильтр от межсетевого экрана прикладного уровня?
4. Почему важно настроить межсетевой экран в корпоративной сети?
5. Назовите три основных режима фильтрации пакетов в межсетевом экране.
6. Какой принцип работы NAT (Network Address Translation)? Зачем он нужен?
7. Что такое DMZ (демитилиаризованная зона) и зачем её используют?
8. Какая разница между правилами разрешения и запрета трафика в настройках межсетевого экрана?
9. Приведи пример ситуации, когда полезно применять правило брандмауэра «разрешить всё, кроме...».
10. Опиши процесс базовой настройки правил межсетевого экрана для безопасной работы интернета в организации.

Цель: изучить технологию применения межсетевого экранирования.

Основные теоретические сведения

1. Межсетевые экраны

Когда речь заходит о защите от атак, то первое, что приходит на ум большинству пользователей, — это межсетевые экраны (firewall). Данная

технология является одной из самых первых и поэтому самой известной.

Межсетевой экран, защищающий сразу множество (не менее двух) узлов, призван решить две задачи, каждая из которых по-своему важна и в зависимости от организации, использующей межсетевой экран, имеет более высокий приоритет по сравнению с другой:

- Ограничение доступа внешних (по отношению к защищаемой сети) пользователей к внутренним ресурсам корпоративной сети. К таким пользователям могут быть отнесены партнеры, удаленные пользователи, хакеры и даже сотрудники самой компании, пытающиеся получить доступ к серверам баз данных, защищаемых межсетевым экраном.

- Разграничение доступа пользователей защищаемой сети к внешним ресурсам. Решение этой задачи позволяет, например, регулировать доступ к серверам, не требуемым для выполнения служебных обязанностей.

Все межсетевые экраны используют в своей работе один из двух взаимоисключающих принципов:

- «Разрешено все, что не запрещено в явном виде». С одной стороны, данный принцип облегчает администрирование межсетевого экрана, т.к. от администратора не требуется никакой предварительной настройки - межсетевой экран начинает работать сразу после включения в сеть электропитания. Любой сетевой пакет, пришедший на МСЭ, пропускается через него, если это не запрещено правилами. С другой стороны, в случае неправильной настройки данное правило делает межсетевой экран дырявым решето, который не защищает от большинства несанкционированных действий, описанных в предыдущих главах. Поэтому в настоящий момент производители межсетевых экранов практически отказались от использования данного принципа.

- «Запрещено все, не разрешено в явном виде». Этот принцип делает межсетевой экран практически неприступной стеной (если на время забыть на возможность подкопа этой стены, ее обхода и проникновения через незащищенные бойницы). Однако, как это обычно и бывает, повышая

защищенность, мы тем самым нагружаем администратора безопасности дополнительными задачами по предварительной настройке базы правил межсетевого экрана. После включения такого МСЭ в сеть, она становится недоступной для любого вида трафика. Администратор должен на каждый тип разрешенного взаимодействия задавать одно и более правил.

Классификация

До сих пор не существует единой и общепризнанной классификации межсетевых экранов. Каждый производитель выбирает удобную для себя классификацию и приводит ее в соответствие с разработанным этим производителем межсетевым экраном. Однако, основываясь на приведенном выше неформальном определении МСЭ, можно выделить следующие их классы, учитывающие уровни OSI или стека TCP/IP:

- коммутаторы, функционирующие на канальном уровне;
- сетевые или пакетные фильтры, которые, как видно из названия, функционируют на сетевом уровне;
- шлюзы сеансового уровня (circuit-level proxy);
- посредники прикладного уровня (application proxy или application gateway);
- инспекторы состояния (stateful inspection).

Коммутаторы

Данные устройства, функционирующие на канальном уровне, не принято причислять к классу межсетевых экранов, т.к. они разграничивают доступ в рамках локальной сети и не могут быть применены для ограничения трафика из Internet. Однако, основываясь на том факте, что межсетевой экран разделяет доступ между двумя сетями или узлами, такое причисление вполне закономерно.

Многие производители коммутаторов, например, Cisco, Nortel, 3Com, позволяют осуществлять фильтрацию трафика на основе MAC-адресов,

содержащихся во фреймах, пытающихся получить доступ к определенному порту коммутатора. Наиболее эффективно данная возможность реализована в решениях компании Cisco, в частности в семействе коммутаторов Catalyst, которые обладают механизмом Port Security. Однако надо заметить, что практически все современные сетевые карты позволяют программно изменять их MAC-адреса, что приводит к неэффективности такого метода фильтрации. Поэтому существуют и другие параметры, которые могут использоваться в качестве признака фильтрации. Например, VLAN, которые разграничивают трафик между ними - трафик одной VLAN никогда не пересекается с трафиком другой VLAN. Более «продвинутые» коммутаторы могут функционировать не только на втором, но и на третьем, четвертом (например, Catalyst) и даже седьмом уровнях модели OSI (например, TopLayer AppSwitch). Необходимо сразу сделать небольшое замечание. Существует некоторая путаница в терминологии. Одни производители упоминают про коммутацию на пятом уровне, другие - на седьмом. И те, и другие правы, но в маркетинговых целях эффектнее выглядит заявление о коммутации на 7-ми, а не 5-ти уровнях. Хотя на самом деле в обоих случаях подразумевается одно и то же. Ведь в модели TCP/IP всего пять уровней и последний, прикладной, уровень включает в себя заключительные три уровня, существующие в модели OSI/ISO.

Таблица 1

Достоинства	Недостатки
Высокая скорость работы.	Отсутствует возможность анализа прикладного уровня.
Данная возможность встроена в большинство коммутаторов, что не требует дополнительных финансовых затрат.	Отсутствует возможность анализа заголовков сетевого и сеансового уровней (исключая некоторые коммутаторы).
	Нет защиты от подмены адреса.

Пакетные фильтры

Пакетные фильтры (packet filter) — это одни из первых и самые

распространенные межсетевые экраны, которые функционируют на третьем, сетевом уровне и принимают решение о разрешении прохождения трафика в сеть на основании информации, находящейся в заголовке пакета. Многие фильтры также могут оперировать заголовками пакетов и более высоких уровней (например, TCP или UDP). Распространенность этих межсетевых экранов связана с тем, что именно эта технология используется в абсолютном большинстве маршрутизаторов (т.н. экранирующий маршрутизатор, screening router) и даже коммутаторах (например, в решениях компании Cisco). В качестве параметров, используемых при анализе заголовков сетевых пакетов, могут использоваться:

- адреса отправителей и получателей;
- тип протокола (TCP, UDP, ICMP и т.д.);
- номера портов отправителей и получателей (для TCP и UDP трафика);
- другие параметры заголовка пакета (например, флаги TCP-заголовка).

С помощью данных параметров, описанных в специальном наборе правил, можно задавать достаточно гибкую схему разграничения доступа. При поступлении пакета на любой из интерфейсов маршрутизатора, он сначала определяет, может ли он доставить пакет по назначению (т.е. может ли осуществить процесс маршрутизации). И только потом маршрутизатор сверяется с набором правил (т.н. список контроля доступа, access control list), проверяя, должен ли он маршрутизировать этот пакет. При создании правил для пакетных фильтров можно использовать два источника информации: внутренний и внешний. Первый источник включает в себя уже названные поля заголовка сетевого пакета. Второй, реже используемый источник оперирует информацией внешней по отношению к сетевым пакетам. Например, дата и время прохождения сетевого пакета.

Сетевые фильтры, обладая рядом достоинств, не лишены и ряда серьезных недостатков. Во-первых, исходя из того, что они анализируют

только заголовок (такие фильтры получили название `stateless packet filtering`), за пределами рассмотрения остается поле данных, которое может содержать информацию, противоречащую политике безопасности. Например, в данном поле может содержаться команда на доступ к файлу паролей по протоколу FTP или HTTP, что является признаком враждебной деятельности. Другой пример. Пакетный фильтр может пропустить в защищаемую сеть TCP-пакет от узла, с которым в настоящий момент не открыто никаких активных сессий. Т.к. межсетевой экран, функционирующий на сетевом уровне, не анализирует информацию, присущую транспортному и более высокому уровню, то он пропустит такой пакет в сеть. В целом, недостаток пакетных фильтров заключается в том, что они не умеют анализировать трафик на прикладном уровне, на котором совершается множество атак - проникновение вирусов, Internet-червей, отказ в обслуживании и т.д. Некоторые производители, например, Cisco, предлагают пакетные фильтры с учетом состояния (`stateful packet filtering`), которые сохраняют в памяти сведения о состоянии текущих сеансов, что позволяет предотвратить некоторые атаки (в частности, описанные в последнем примере).

Другой недостаток пакетных фильтров - сложность настройки и администрирования. Приходится создавать как минимум два правила для каждого типа разрешенного взаимодействия (для входящего и исходящего трафика). Мало того, некоторые правила, например, реализованные в решениях компании Cisco, различаются для каждого интерфейса маршрутизатора, что только усложняет создание таблицы правил (списка контроля доступа). Неконтролируемое увеличение числа правил может приводить к появлению брешей в первой линии обороны, создаваемой пакетными фильтрами. Известны случаи, когда таблицы правил маршрутизаторов содержали тысячи правил. Только представьте, с какой головной болью столкнулись бы администраторы, пожелавшие локализовать какую-либо проблему с пропуском трафика. И не стоит забывать, что при настройке фильтра может случиться ситуация, когда одно правило

противоречит другому. Увеличение числа правил несет с собой и еще одну проблему - снижение производительности межсетевого экрана. Ведь пришедший пакет проверяется на соответствие таблицы правил, начиная с ее верха, что в свою очередь требует внимательного отношения к порядку следования правил. Такая проверка осуществляется до тех пор, пока не будет найдено соответствующее правило или не будет достигнут конец таблицы. Во многих реализациях, каждое новое правило, пусть ненамного, но все же уменьшает общую производительность фильтра. Одним из немногих исключений является уже неоднократно упоминавшаяся продукция компании Cisco, в которой реализованы высокоэффективные механизмы обработки сетевого трафика.

Еще один недостаток пакетных фильтров - слабая аутентификация трафика, которая осуществляется только на основе адреса отправителя. Текущая версия протокола IP (v4) позволяет без труда подменять такой адрес, подставляя вместо него любой из адресов, принадлежащий адресному пространству IP-протокола, реализуя тем самым атаку «подмена адреса» (IP Spoofing). И даже, если адрес компьютера-отправителя не изменялся, то что мешает злоумышленнику сесть за этот компьютер. Ведь сетевой фильтр не запрашивает у пакета идентификатор и пароль пользователя, т.к. эта информация принадлежит прикладному уровню.

Данные МСЭ могут быть реализованы как аппаратно, например, в фильтрующих маршрутизаторах компании Cisco, так и программно, например, в ОС Windows и Unix. Причем пакетный фильтр может быть установлен не только на устройстве, расположенном на границе между двумя сетями (например, на маршрутизаторе), но и на рабочей станции пользователя, повышая тем самым ее защищенность.

Однако простота реализации пакетных фильтров, их высокая производительность и малая цена (зачастую такие фильтры являются свободно распространяемыми) перевешивает указанные недостатки и обуславливает их повсеместное распространение и использование как

обязательного (а зачастую единственного) элемента системы сетевой безопасности. Кроме того, они являются составной частью практически всех межсетевых экранов, использующих контроль состояния и описываемых далее.

Таблица 2

Достоинства	Недостатки
Высокая скорость работы.	Отсутствует возможность анализа прикладного уровня.
Простота реализации.	Нет защиты от подмены адреса.
Данная возможность встроена во все маршрутизаторы и многие ОС, что не требует дополнительных финансовых затрат.	Сложность настройки и администрирования.
Низкая стоимость или свободное распространение (в случае приобретения).	При увеличении числа правил возможно снижение производительности.
	Требуется детальное знание сетевых услуг и протоколов.
	Нет контроля состояния соединения.
	Трудность функционирования в сетях с динамическим распределением адресов.

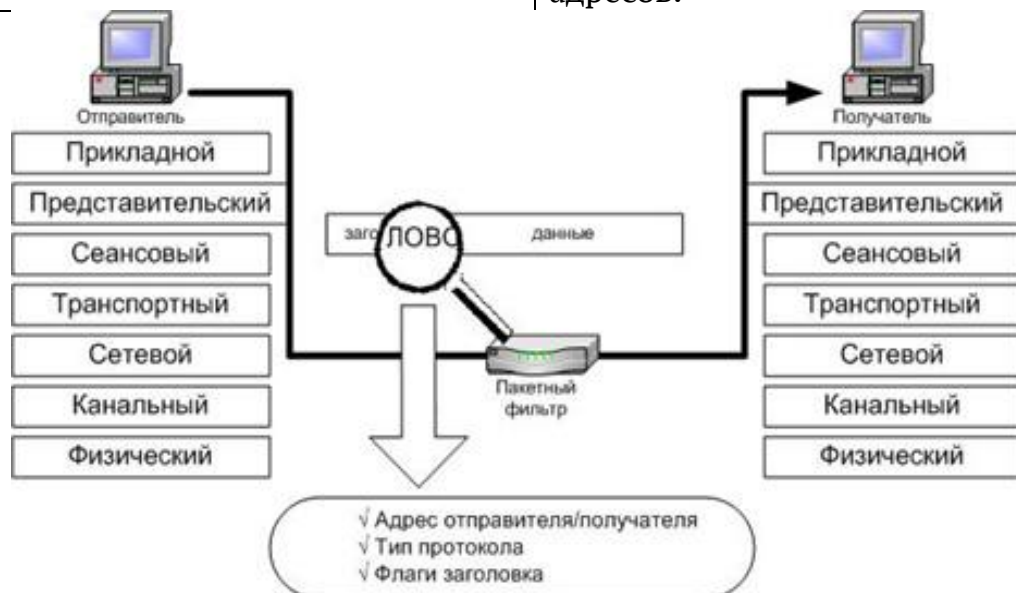


Рисунок 1 – Пакетный фильтр

Шлюзы сеансового уровня

Шлюз сеансового уровня — это другая технология, используемая в

межсетевых экранах, но на сегодняшний день ее очень трудно встретить в виде единственной технологии, реализованной в межсетевом экране. Как правило, они поставляются в рамках прикладных шлюзов или инспекторов состояний. Кроме того, обеспечиваемый им уровень защиты немногим выше, чем у пакетных фильтров, при более низкой производительности.

Смысл технологии фильтрации на сеансовом уровне заключается в том, что шлюз исключает прямое взаимодействие двух узлов, выступая в качестве т.н. посредника (проху), который перехватывает все запросы одного узла на доступ к другому и, после проверки допустимости таких запросов, устанавливает соединение. После этого шлюз сеансового уровня просто копирует пакеты, передаваемые в рамках одной сессии, между двумя узлами, не осуществляя дополнительной фильтрации. Как только авторизованное соединение установлено, шлюз помещает в специальную таблицу соединений соответствующую информацию (адреса отправителя и получателя, состояние соединения, информация о номере последовательности и т.д.). Как только сеанс связи завершается, запись о нем удаляется из этой таблицы. Все последующие пакеты, которые могут быть сформированы злоумышленником и «как бы относятся» к уже завершенному соединению, отбрасываются.

Достоинство данной технологии, ярким представителем которой является SOCKS в том, что она исключает прямой контакт между двумя узлами. Адрес шлюза сеансового уровня является единственным элементом, который связывает внешнюю сеть, кишущую хакерами, с внутренними, защищаемыми ресурсами. Кроме того, поскольку соединение между узлами устанавливается только после проверки его допустимости, то тем самым шлюз предотвращает возможность реализации подмены адреса, присущую пакетным фильтрам.

Несмотря на кажущуюся эффективность этой технологии, у нее есть один очень серьезный недостаток - невозможность проверки содержания поля данных. Т.е. тем самым злоумышленнику представляется возможность передачи в защищаемую сеть троянских коней и других Internet-напастей.

Мало того, описанная в предыдущих главах возможность перехвата ТСР-сессии (TCP hijacking), позволяет злоумышленнику даже в рамках разрешенной сессии реализовывать свои атаки.

Таблица 3

Достоинства	Недостатки
Высокая скорость работы.	Отсутствует возможность анализа прикладного уровня.
Простота реализации.	
Исключение прямого взаимодействия между двумя узлами.	
Контроль состояния соединения.	

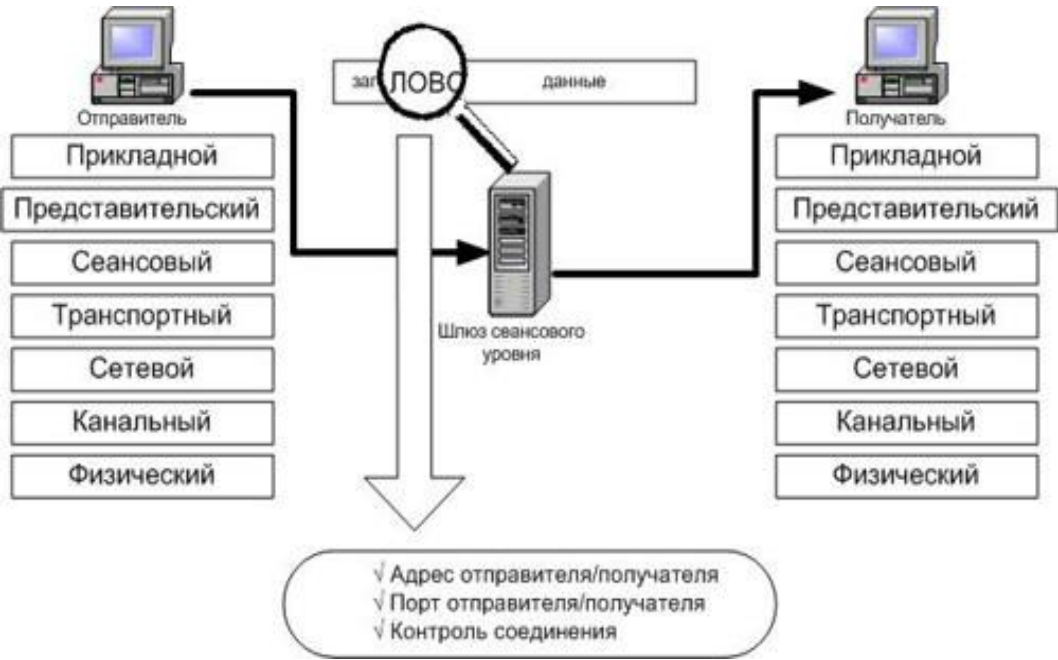


Рисунок 2 – «Шлюз сеансового уровня»

Посредники прикладного уровня

Посредники прикладного уровня практически ничем не отличаются от шлюзов сеансового уровня, за одним исключением. Они также осуществляют посредническую функцию между двумя узлами, исключая их непосредственное взаимодействие, но позволяют проникать в контекст передаваемого трафика, т.к. функционируют на прикладном уровне.

Межсетевые экраны, построенные по этой технологии, содержат т.н. посредников приложений (application proxy), которые, «зная» как функционирует то или иное приложение, могут обрабатывать сгенерированный ими трафик. Таким образом, эти посредники могут, например, разрешать в исходящем трафике команду GET (получение файла) протокола FTP и запрещать команду PUT (отправка файла) и наоборот. Еще одно отличие от шлюзов сеансового уровня - возможность фильтрации каждого пакета.

Однако, как видно из приведенного описания, если для какого-либо из приложений отсутствует свой посредник приложений, то межсетевой экран не сможет обрабатывать трафик такого приложения, и он будет отбрасываться. Именно поэтому так важно, чтобы производитель межсетевого экрана своевременно разрабатывал посредники для новых приложений, например, для мультимедиа приложений.

Таблица 4

Достоинства	Недостатки
Анализ на прикладном уровне и возможность реализации дополнительных механизмов защиты (например, анализ содержимого).	Невозможность анализа трафика от «неизвестного» приложения.
Исключение прямого взаимодействия между двумя узлами.	Невысокая производительность.
Высокий уровень защищенности.	Уязвимость к атакам на уровне ОС и приложений.
Контроль состояния соединения.	Требование изменения модификации клиентского ПО.
	Не всегда есть посредник для приложений на базе протоколов UDP и RPC.
	Двойной анализ - на уровне приложения и уровне посредника.

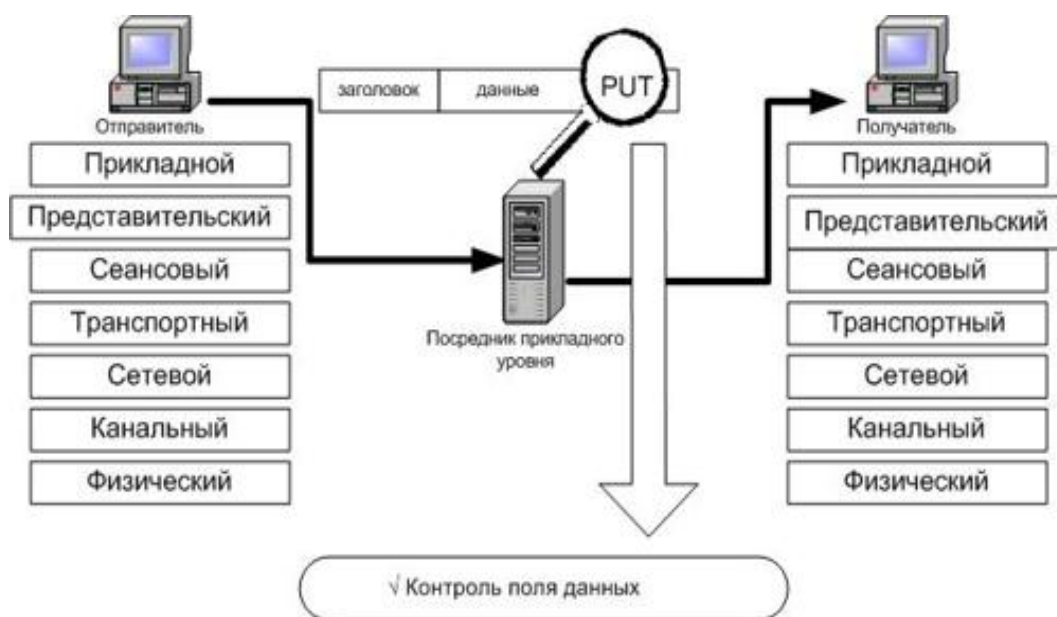


Рисунок 3 «Посредник прикладного уровня»

Инспекторы состояния.

Каждый из названных классов межсетевых экранов обладает рядом достоинств и может применяться для защиты корпоративных сетей. Однако куда более эффективным было бы объединить все названные классы МСЭ в одном устройстве. Что и было сделано в инспекторах состояний, которые совмещают в себе все достоинства названных выше типов экранов, начиная анализ трафика с сетевого и заканчивая прикладными уровнями, что позволяет совместить в одном устройстве, казалось бы, несовместимые вещи - большую производительность и высокую защищенность. Эти межсетевые экраны позволяют контролировать:

- каждый передаваемый пакет - на основе имеющейся таблицы правил;
- каждую сессию - на основе таблицы состояний;
- каждое приложение - на основе разработанных посредников.

Действуя по принципу «продвинутого» шлюза сеансового уровня, инспектор состояния, тем не менее, не препятствует установлению соединения между двумя узлами, за счет производительность такого меж сетевого экрана существенно выше, чем у шлюза сеансового и прикладного уровня,

приближаясь к значениям, встречающимся только у пакетных фильтров. Еще одно достоинство межсетевых экранов с контролем состояния - прозрачность для конечного пользователя, не требующая дополнительной настройки или изменения конфигурации клиентского программного обеспечения.

Завершая описание классов межсетевых экранов, хотим заметить, что термин «stateful inspection», введенный компанией Check Point Software, так полюбился производителям, что сейчас очень трудно найти межсетевой экран, который бы не относили к этой категории (даже если он и не реализует эту технологию). Таким образом, сейчас на рынке существует всего два класса межсетевых экранов - инспекторы состояний и пакетные фильтры.

Выбор межсетевого экрана

Нельзя сделать однозначный выбор в пользу какого-либо из названных экранов. Лучше если вы сможете использовать два межсетевых экрана, строя таким образом, эшелонированную оборону своей сети. Если один из экранов будет выведен из строя, то до тех пор его работоспособность не будет восстановлена, весь удар примет на себя второй экран. Обычно используется комбинация «пакетный фильтр - инспектор состояния (или посредник прикладного уровня)». И эта комбинация хороша еще и тем, что вам не придется тратить на приобретение пакетного фильтра, уже встроенного в маршрутизатор, установленный на границе вашей сети.

Возможности

Помимо фильтрации трафика межсетевые экраны позволяют выполнять и другие, не менее важные функции, без которых обеспечение защиты периметра было бы неполным. Разумеется, приводимый ниже список не является исчерпывающим, но и данный материал не является руководством по выбору межсетевого экрана. Мы всего лишь указываем на некоторые средства защиты от атак, описанных ранее.

Трансляция сетевых адресов

Как показано ранее, для реализации многих атак злоумышленнику необходимо знать адрес своей жертвы. Чтобы скрыть эти адреса, а также топологию всей сети, межсетевые экраны выполняют очень важную функцию - трансляцию сетевых адресов (network address translation). Трансляция может осуществляться двумя способами - динамически и статически. В первом случае адрес выделяется узлу в момент обращения к межсетевому экрану. После завершения соединения адрес освобождается и может быть использован любым другим узлом корпоративной сети. Во втором случае адрес узла всегда привязывается к одному адресу МСЭ.

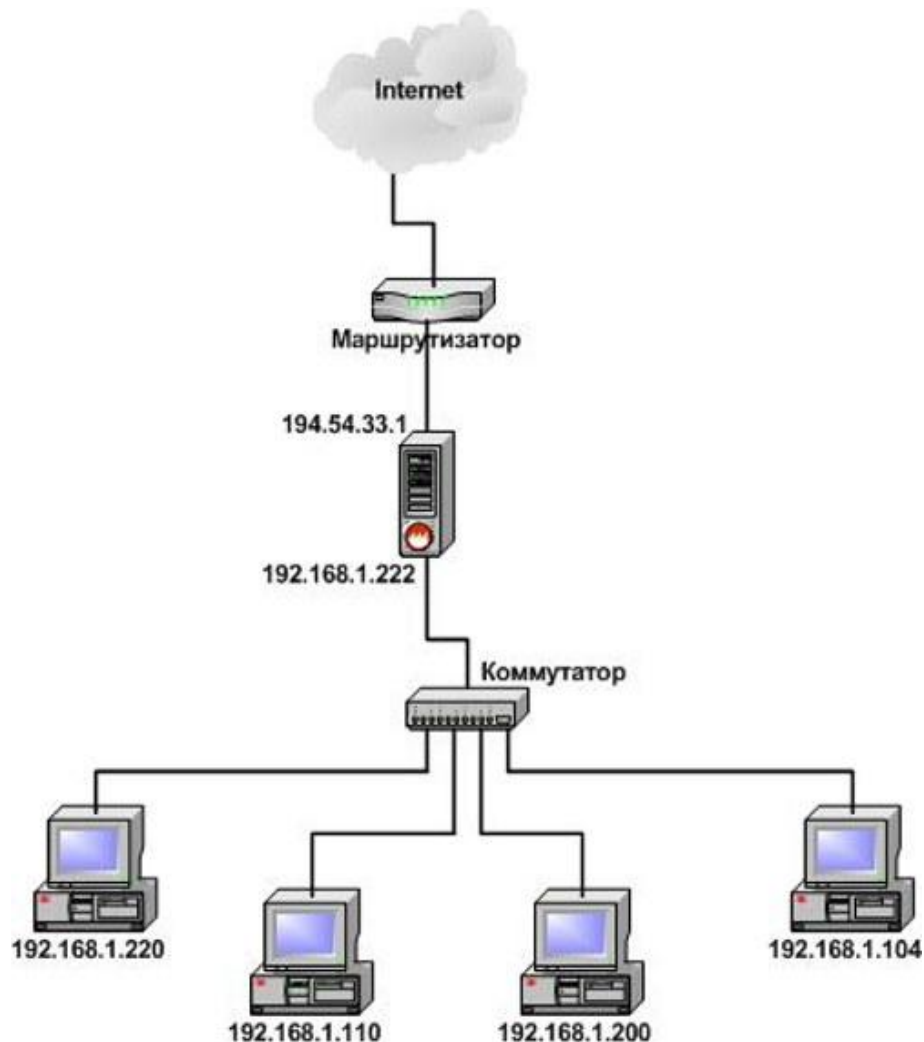


Рисунок 4 – «Трансляция сетевых адресов»

Аутентификация пользователей

Межсетевые экраны помимо разрешения или запрещения допуска

различных приложений в сеть, также могут выполнять аналогичные действия и для пользователей, которые желают получить доступ к внешним или внутренним ресурсам, разделяемым межсетевым экраном. При этом проверка подлинности (аутентификация) пользователя может осуществляться как при предъявлении обычного идентификатора (имени) и пароля, так и с помощью более надежных методов, например, с помощью SecureID или цифровых сертификатов.

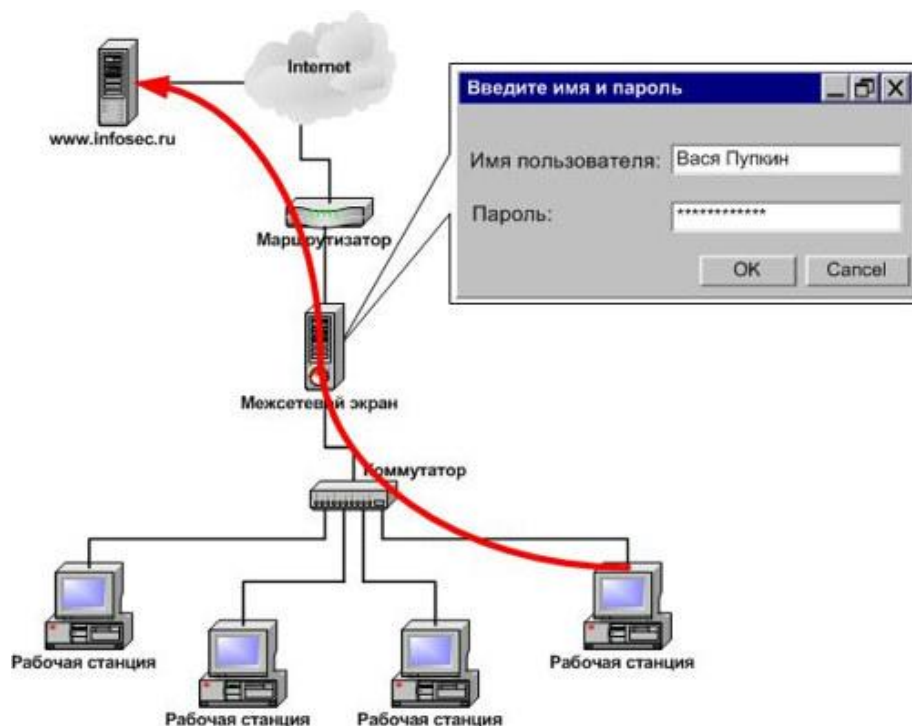


Рисунок 5 – «Аутентификация»

Регистрация событий

Являясь критическим элементом системы защиты корпоративной сети, межсетевой экран имеет возможность регистрации всех действий, им фиксируемых. К таким действиям относятся не только пропуск или блокирование сетевых пакетов, но и изменение правил разграничения доступа администратором безопасности и другие действия. Такая регистрация позволяет обращаться к создаваемым журналам по мере необходимости - в случае возникновения инцидента безопасности или сбора доказательств для предоставления их в судебные инстанции или для внутреннего расследования.

Реализация

Существует два варианта реализации межсетевых экранов: программный и программно-аппаратный. Второй вариант также может быть реализован двояко - в виде специализированного устройства и в виде модуля в маршрутизаторе или коммутаторе. Интерес к программно-аппаратным решениям за последние два года во всем мире возрос постепенно, вытесняя «чисто» программные системы.

Первое решение - наиболее часто используемое в настоящее время и на первый взгляд более привлекательное. Это связано с тем, что, по мнению многих, для его применения достаточно только приобрести программное обеспечение меж сетевого экрана и установить на любой компьютер, имеющийся в организации. Однако на практике далеко не всегда в организации находится свободный компьютер, да еще и удовлетворяющий достаточно высоким требованиям по системным ресурсам. Поэтому одновременно с приобретением программного обеспечения приобретается и компьютер для его установки. Потом следует процесс установки на компьютер операционной системы и ее настройка, что также требует времени и оплаты работы установщиков. И только после этого устанавливается, и настраивается программное обеспечение системы обнаружения атак. Как видно, использование обычной персоналки далеко не так просто, как кажется на первый взгляд. Именно поэтому в последние годы стали получать распространения специализированные программно-аппаратные решения, называемые security appliance. Они поставляются, как специальные программно-аппаратные комплексы, использующие специализированные или обычные операционные системы (как правило, на базе FreeBSD или Linux), «урезанные» для выполнения только заданных функций. К достоинству таких решений можно отнести:

простота внедрения в технологию обработки информации. Поскольку такие устройства поставляются уже с предустановленной настроенной

операционной системой, и защитными механизмами, необходимо только подключить его к сети, что выполняется в течение нескольких минут. И хотя некоторая настройка все же требуется, время, затрачиваемое на нее, существенно меньше, чем в случае установки и настройки межсетевого экрана «с нуля».

простота управления. Данные устройства могут управляться с любой ОС (Windows, Unix). Взаимодействие консоли управления с устройством осуществляется либо по стандартным протоколам, например, Telnet или SNMP, либо при помощи специализированных или защищенных протоколов, например, Ssh или SSL.

производительность. За счет того, что из операционной системы исключаются все «ненужные» сервисы и подсистемы, устройство работает более эффективно с точки зрения производительности и надежности.

отказоустойчивость и высокая доступность. Реализация межсетевого экрана в специальном устройстве позволяет реализовать механизмы обеспечения не только программной, но и аппаратной отказоустойчивости и высокой доступности. Такие устройства относительно легко объединяются в кластеры.

сосредоточение на защите. Решение только задач обеспечения сетевой безопасности не приводит к трате ресурсов на выполнение других функций, например, маршрутизации и т.п.

Однако сразу необходимо заметить, что специализированный компьютер – это не то же самое, что маршрутизатор с функциями обнаружения атак (например, маршрутизаторы с Cisco Secure Integrated Software). У производителя маршрутизаторов приоритетной задачей всегда является улучшение процесса и повышение скорости маршрутизации. И только затем он пытается реализовать функции защиты. Поэтому, делая выбор между маршрутизацией и защитой, они всегда делают его в пользу маршрутизации. Как показывает практика, использование защитных механизмов на маршрутизаторах существенно снижает их

производительность. Либо же защитные функции ограничены.

Недостатки

Выше уже были перечислены некоторые недостатки, присущие межсетевым экранам, а также способы их обхода. Ниже мы укажем еще некоторые из них.

Ограничение функциональности сетевых сервисов

Некоторые корпоративные сети используют топологии, которые трудно «уживаются» с межсетевым экраном (например, широковещательная рассылка трафика), или используют некоторые сервисы (например, NFS) таким образом, что применение МСЭ требует существенной перестройки всей сетевой инфраструктуры. В такой ситуации относительные затраты на приобретение и настройку межсетевого экрана могут быть сравнимы с ущербом, связанным с отсутствием МСЭ.

Решить данную проблему можно только путем правильного проектирования топологии сети на начальном этапе создания корпоративной информационной системы. Это позволит не только снизить последующие материальные затраты на приобретение средств защиты информации, но и эффективно встроить межсетевые экраны в существующую технологию обработки информации. Если сеть уже спроектирована и функционирует, то, возможно, стоит подумать о применении вместо межсетевого экрана какого-либо другого решения, например, системы обнаружения атак.

Потенциально опасные возможности

Новые возможности, которые появились недавно, и которые облегчают жизнь пользователям Internet, разрабатывались практически без учета требований безопасности. Например, JavaScript, Java, ActiveX и другие сервисы, ориентированные на работу с данными. Специфика мобильного кода такова, что он может быть использован и как средство для проведения атак, и

как объект атаки. В первом варианте опасность заключается в том, что мобильный код загружается на компьютер пользователя и выполняется на нем как обычная программа, получая доступ к системным ресурсам. Вторым вариантом, как правило, используется для модификации мобильного кода - как предварительный этап перед проведением атак на локальный компьютер пользователя. Атаки на мобильный код, как на средство выполнения каких-либо функций, пока не получили широкого распространения. Связано это с тем, что мобильный код пока не применяется для выполнения каких-либо серьезных операций, например, проведения финансовых транзакций. Хотя уже известны примеры банковских систем, в том числе и российских, использующих технологию Java для работы с клиентом.

Персональные межсетевые экраны

За последние несколько лет в структуре корпоративных сетей произошли серьезные изменения. Если раньше границы таких сетей можно было четко очертить, то сейчас это практически невозможно. Еще недавно такая граница проходила через все маршрутизаторы или иные устройства (например, модемы), через которые осуществлялся выход во внешние сети. В удаленных офисах организации ситуация была схожа. Однако сейчас полноправным пользователем защищаемой межсетевым экраном сети является сотрудник, находящийся за пределами защищаемого периметра. К таким сотрудникам относятся пользователи, работающие на дому или находящиеся в командировке. Требуется ли им защита? Несомненно. Но все традиционные межсетевые экраны построены так, что защищаемые пользователи и ресурсы должны находиться под сенью их защиты, т.е. с внутренней стороны, что является невозможным для мобильных пользователей. Чтобы устранить эту проблему было предложено два подхода - виртуальные частные сети (virtual private network, VPN), которые будут описаны далее, и распределенные межсетевые экраны (distributed firewall). Примером первого решения можно назвать VPN-1 компании Check Point

Software (<http://www.checkpoint.com>). Такая схема, похожая на осьминога, раскинувшего свои щупальца, обладала только одним недостатком - сам удаленный узел был подвержен атакам, хотя доступ в корпоративную сеть был защищен от несанкционированных воздействий. Установленный на удаленное рабочее место троянский конь мог дать возможность проникнуть злоумышленнику через межсетевой экран и по защищенному каналу. Ведь VPN шифрует и обычный, и несанкционированный трафик, не делая между ними различий. Тогда-то и родилась идея распределенного межсетевого экрана (distributed firewall), который являлся бы мини-экраном, защищающим не всю сеть, а только отдельный компьютер. Примерами такого решения является BlackICE Agent компании Internet Security Systems (<http://www.iss.net>) или RealSecure Server Sensor того же производителя. Это решение понравилось и домашним пользователям, которые наконец-то получили возможность защиты своих компьютеров от рыскающих по сети злоумышленников. Но, т.к. многие функции распределенного МСЭ (например, централизованное управление или рассылка политики безопасности) для домашних пользователей были лишними, то технология распределенного МСЭ была модифицирована и новый подход получил название «персонального межсетевого экрана» (personal firewall), яркими представителями которых являются ZoneAlarm, и BlackICE Defender компаний ZoneLabs (<http://www.zonelabs.com>) и ISS соответственно. Компания Check Point Software оказалась впереди и здесь, предложив решение VPN-1 SecureClient и VPN-1 SecureServer, которые не только защищают от внешних атак компьютеры, на которых они установлены, но и обеспечивают защиту трафика, передаваемого за пределы данного узла (т.е. организуя client\server VPN). Именно такое решение сделало подвластными межсетевым экранам сети с нечетко очерченными границами.

В чем отличие персонального межсетевого экрана от распределенного? Главное отличие одно - наличие функции централизованного управления. Если персональные межсетевые экраны управляются только с того

компьютера, на котором они установлены, и идеально подходят для домашнего применения, то распределенные межсетевые экраны могут управляться централизованно, с единой консоли управления, установленной в главном офисе организации. Такие отличия позволили некоторым производителям выпускать свои решения в двух версиях - персональной (для домашних пользователей) и распределенной (для корпоративных пользователей). Так, например, поступила компания Internet Security Systems, которая предлагает персональный межсетевой экран BlackICE Defender и распределенный межсетевой экран BlackICE Agent.

Какими функциями должен обладать эффективный персональный МСЭ? Во-первых, этот экран не должен быть пассивной программой, которая только и делает, что блокирует входящий на компьютер трафик по заданным критериям, к которым обычно относятся адрес и порт источника. Злоумышленники давно научились обходить такие простые защитные механизмы и в сети Internet можно найти большое число программ, которые могут проникнуть через многие традиционные защитные барьеры. Примером такой программы является троянский конь SubSeven 2.2, позволяющий выполнять большое число функций на скомпрометированном компьютере без ведома его владельца. Чтобы защититься, необходим инструмент, который позволит проводить более глубокий анализ каждого сетевого пакета, направленного на защищаемый узел. Таким инструментом является система обнаружения атак, которая в трафике, пропущенном через межсетевой экран, обнаруживает следы хакерской деятельности. Она не доверяет слепо таким разрешительным признакам, как адрес и порт источника. Как известно протокол IP, на основе которого построен современный Internet, не имеет серьезных механизмов защиты, что позволяет без труда подменить свой настоящий адрес, тем самым, делая невозможным отслеживание злоумышленника. Мало того, хакер может «подставить» кого-нибудь другого, заменив свой адрес на адрес подставного лица. И, наконец, для некоторых атак (например, «отказ в обслуживании») адрес источника вообще не нужен и по

статистике в 95% случаев этот адрес хакером изменяется. Можно привести хорошую аналогию. Персональный межсетевой экран — это охранник в здании, который выписывает пропуска всем посетителям. В такой ситуации злоумышленник может без труда пронести в здание оружие или бомбу. Однако если на входе поставить металлодетектор, то ситуация в корне меняется и злоумышленнику уже не так легко пронести в защищаемую зону запрещенные предметы.

К сожалению, приходится отметить, что немногие межсетевые экраны обладают встроенной системой обнаружения атак. Одним из таких решений является системы BlackICE Defender и BlackICE Agent компании Internet Security Systems. Любой из компонентов семейства BlackICE содержит два основных модуля, осуществляющих обнаружение и блокирование несанкционированной деятельности - BlackICE Firewall и BlackICE IDS. BlackICE Firewall отвечает за блокирование сетевого трафика с определенных IP-адресов и TCP/UDP-портов. Предварительное блокирование трафика по определенным критериям позволяет увеличить производительность системы за счет снижения числа «лишних» операций на обработку неразрешенного трафика. Настройка данного компонента может осуществляться как вручную, так и в автоматическом режиме. В последнем случае, реконфигурация происходит после обнаружения несанкционированной деятельности модулем BlackICE IDS. При этом блокирование трафика может осуществляться на любой промежуток времени. BlackICE Firewall работает напрямую с сетевой картой, минуя встроенный в операционную систему стек протоколов, что позволяет устранить опасность от использования многих известных уязвимостей, связанных с некорректной реализацией стека в ОС. BlackICE IDS отвечает за обнаружение атак и других следов несанкционированной деятельности в трафике, поступающем от модуля BlackICE Firewall, и использует запатентованный алгоритм семиуровневого анализа протокола.

Следующим механизмом, которым должен обладать эффективный персональный межсетевой экран, является защита от опасного содержимого,

которое можно получить из Internet. К такому содержимому можно отнести апплеты Java и управляющие элементы ActiveX, код ShockWave и сценарии JavaScript, Jscript и VBScript. С помощью этих, с одной стороны незаменимых и удобных технологий, можно выполнить большое число несанкционированных действий на компьютере. Начиная от внедрения вирусов и установки троянских коней и заканчивая кражей или удалением всей информации. Также персональные межсетевые экраны должны защищать от cookies, которые могут раскрыть конфиденциальную информацию о владельце компьютера.

В некоторые персональные МСЭ (например, в Norton Internet Security компании Symantec) встроены антивирусные системы, которые помимо обнаружения троянцев могут обнаруживать и большое число вирусов, включая макрос-вирусы и Internet-червей. Зачастую производители встраивают в свою продукцию модули VPN (например, PGP Desktop Security или VPN-1 SecureClient), которые отвечают за обеспечение защищенного взаимодействия с центральным офисом.

Т.к. распределенные экраны управляются централизованно, то они должны обладать эффективным механизмом настройки, администрирования и контроля, позволяющим администратору безопасности без дополнительных усилий получить подробную информацию о зафиксированных попытках проникновения на защищаемые узлы. Мало того, в некоторых случаях необходимо инициировать процедуру расследования компьютерного преступления или собрать доказательства для обращения в правоохранительные органы. И здесь будет незаменимым механизм отслеживания злоумышленника (back tracing), реализованный в некоторых межсетевых экранах. Например, уже упоминаемые BlackICE Agent и Defender, позволяют отследить злоумышленника, осуществляющего атаку на защищаемый компьютер, и собрать о хакере следующую информацию:

- IP-, DNS-, WINS-, NetBIOS- и MAC-адреса компьютера, с которого осуществляется атака;

- имя, под которым злоумышленник вошел в сеть.

Немаловажной является возможность удаленного обновления программного обеспечения персонального межсетевого экрана (например, в VPN-1 SecureClient). В противном случае администратору приходилось бы самостоятельно посещать каждого из владельцев компьютера и обновлять его защитное ПО. Представьте, какую бурю возмущений это вызвало бы у владельцев компьютеров, которых отрывали бы от своей работы. Удаленное же и, главное, незаметное для владельца компьютера, обновление (включая и обновление сигнатур атак и вирусов) снимает эту проблему и облегчает нелегкий труд администратора безопасности. Осуществляя удаленное управление, не стоит забывать и о защите трафика, передаваемого между центральной консолью и удаленными агентами. Злоумышленник может перехватить или подменить эти команды, что нарушит защищенность удаленных узлов.

2. ACL: списки контроля доступа (на примере Cisco IOS)

ACL (Access Control List) — это набор текстовых выражений, которые что-то разрешают, либо что-то запрещают. Обычно ACL разрешает или запрещает IP-пакеты, но помимо всего прочего он может заглядывать внутрь IP-пакета, просматривать тип пакета, TCP и UDP порты. Также ACL существует для различных сетевых протоколов (IP, IPX, AppleTalk и так далее). В основном применение списков доступа рассматривают с точки зрения пакетной фильтрации, то есть пакетная фильтрация необходима в тех ситуациях, когда у вас стоит оборудование на границе Интернет и вашей частной сети и нужно отфильтровать ненужный трафик.

Функционал ACL состоит в классификации трафика, нужно его проверить сначала, а потом что-то с ним сделать в зависимости от того, куда ACL применяется. ACL применяется везде, например:

- на интерфейсе: пакетная фильтрация;
- на линии Telnet: ограничения доступа к маршрутизатору;

- VPN: какой трафик нужно шифровать;
- QoS: какой трафик обрабатывать приоритетнее;
- NAT: какие адреса транслировать.

Для применения ACL для всех этих компонентов нужно понять, как они работают. И мы в первую очередь будем касаться пакетной фильтрации. Применительно к пакетной фильтрации, ACL размещаются на интерфейсах, сами они создаются независимо, а уже потом они прикручиваются к интерфейсу. Как только вы его прикрутили к интерфейсу маршрутизатор начинает просматривать трафик. Маршрутизатор рассматривает трафик как входящий и исходящий. Тот трафик, который входит в маршрутизатор называется входящим, тот который из него выходит – исходящий. Соответственно ACL размещаются на входящем или на исходящем направлении.

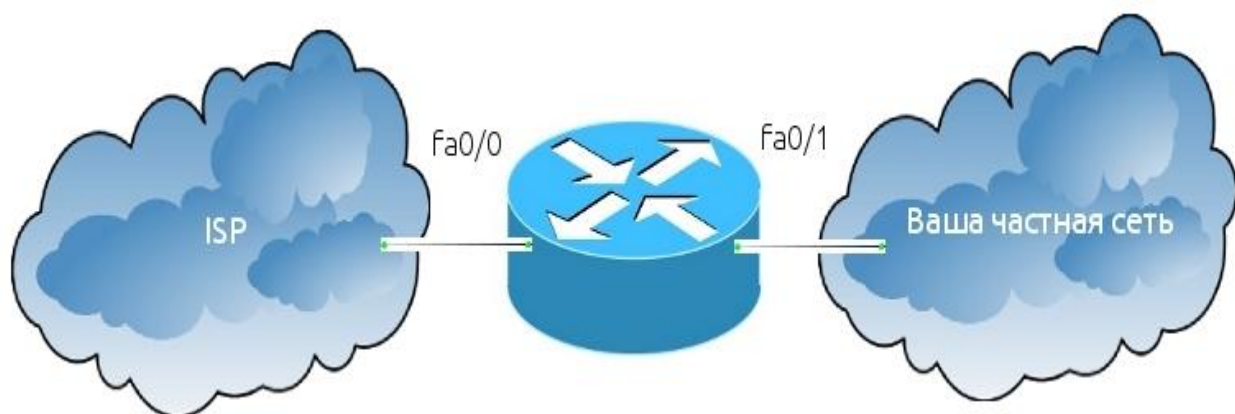


Рисунок 6

Из вашей частной сети приходит пакет на интерфейс маршрутизатора fa0/1, маршрутизатор проверяет есть ли ACL на интерфейсе или нет, если он есть, то дальше обработка ведется по правилам списка доступа строго в том порядке, в котором записаны выражения, если список доступа разрешает проходить пакету, то в данном случае маршрутизатор отправляет пакет провайдеру через интерфейс fa0/0, если список доступа не разрешает проходить пакету, пакет уничтожается. Если списка доступа нет — пакет пролетает без всяких ограничений. Перед тем как отправить пакет провайдеру, маршрутизатор ещё проверяет интерфейс fa0/0 на наличие исходящего ACL.

Дело в том, что ACL может быть прикреплен на интерфейсе как входящий или исходящий. К примеру, у нас есть ACL с правилом запретить всем узлам в Интернете посылать в нашу сеть пакеты.

Так на какой интерфейс прикрепить данную ACL? Если мы прикрепим ACL на интерфейс fa0/1 как исходящий, это будет не совсем верно, хотя и ACL работать будет. На маршрутизатор приходит эхо-запрос для какого-то узла в частной сети, он проверяет на интерфейсе fa0/0 есть ли ACL, его нет, дальше проверяет интерфейс fa0/1, на данном интерфейсе есть ACL, он настроен как исходящий, всё верно пакет не проникает в сеть, а уничтожается маршрутизатором. Но если мы прикрепим ACL за интерфейсом fa0/0 как входящий, то пакет будет уничтожаться сразу как пришел на маршрутизатор. Последнее решение является правильным, так как маршрутизатор меньше нагружает свои вычислительные ресурсы. Расширенные ACL нужно размещать как можно ближе к источнику, стандартные же как можно ближе к получателю. Это нужно для того, чтобы не гонять пакеты по всей сети зря.

Сам же ACL представляет собой набор текстовых выражений, в которых написано `permit` (разрешить) либо `deny` (запретить), и обработка ведется строго в том порядке, в котором заданы выражения. Соответственно, когда пакет попадает на интерфейс он проверяется на первое условие, если первое условие совпадает с пакетом, дальнейшая его обработка прекращается. Пакет либо перейдет дальше, либо уничтожится.

Ещё раз, если пакет совпал с условием, дальше он не обрабатывается. Если первое условие не совпало, идет обработка второго условия, если оно совпало, обработка прекращается, если нет, идет обработка третьего условия и так дальше пока не проверятся все условия, если никакое из условий не совпадает, пакет просто уничтожается. Помните, в каждом конце списка стоит неявный `deny any` (запретить весь трафик). Будьте очень внимательны с этими правилами, которые я выделил, потому что очень часто происходят ошибки при конфигурации.

ACL разделяются на два типа:

- стандартные (Standard): могут проверять только адреса источников;

- расширенные (Extended): могут проверять адреса источников, а также адреса получателей, в случае IP ещё тип протокола и TCP/UDP порты.

Обозначаются списки доступа либо номерами, либо символьными именами. ACL также используются для разных сетевых протоколов. Мы в свою очередь будем работать с IP. Обозначаются они следующим образом, нумерованные списки доступа:

- стандартные: от 1 до 99;

- расширенные: от 100 до 199.

Символьные ACL разделяются тоже на стандартные и расширенные. Расширенные напомню могут проверять гораздо больше, нежели стандартные, но и работают они медленнее, так как придется заглядывать внутрь пакета, в отличие от стандартных, где мы смотрим только поле Source Address (Адрес отправителя). При создании ACL каждая запись списка доступа обозначается порядковым номером, по умолчанию в рамках десяти (10, 20, 30 и т.д). Благодаря чему, можно удалить конкретную запись и на её место вставить другую, но эта возможность появилась в Cisco IOS 12.3, до 12.3 приходилось ACL удалять, а потом создать заново полностью. Нельзя разместить более 1 списка доступа на интерфейс, на протокол, на направление. Объясняю: если у нас есть маршрутизатор и у него есть интерфейс, мы можем на входящее направление для IP-протокола разместить только один список доступа, например под номером 10. Ещё одно правило, касающееся самих маршрутизаторов, ACL не действует на трафик, сгенерированный самим маршрутизатором.

Для фильтрации адресов в ACL используется WildCard-маска. Это обратная маска. Берем шаблонное выражение: 255.255.255.255 и отнимаем от шаблона обычную маску.

255.255.255.255-255.255.255.0, у нас получается маска 0.0.0.255, что является обычной маски 255.255.255.0, только 0.0.0.255 является WildCard

маской.

Виды ACL

Динамический (Dynamic ACL)

Позволяет сделать следующее: например, у вас есть маршрутизатор, который подключен к какому-то серверу и нам нужно закрыть доступ к нему из внешнего мира, но в тоже время есть несколько человек, которые могут подключаться к серверу.

Мы настраиваем динамический список доступа, прикрепляем его на входящем направлении, а дальше людям, которым нужно подключиться, подключаться через Telnet к данному устройству, в результате динамический ACL открывает проход к серверу, и уже человек может зайти скажем через HTTP попасть на сервер. По умолчанию через 10 минут этот проход закрывается, и пользователь вынужден ещё раз выполнить Telnet чтобы подключиться к устройству.

Рефлексивный (Reflexive ACL)

Здесь ситуация немножко отличается, когда узел в локальной сети отправляет TCP запрос в Интернет, у нас должен быть открытый проход, чтобы пришел TCP ответ для установки соединения. Если прохода не будет — мы не сможем установить соединение, и вот этим проходом могут воспользоваться злоумышленники, например, проникнуть в сеть. Рефлексивные ACL работают таким образом, блокируется полностью доступ (deny any) но формируется ещё один специальный ACL, который может читать параметры пользовательских сессий, которые сгенерированы из локальной сети и для них открывать проход в deny any, в результате получается что из Интернета не смогут установить соединение. А на сессии сгенерированы из локальной сети будут приходить ответы.

Ограничение по времени (Time-based ACL)

Обычный ACL, но с ограничением по времени, вы можете ввести специальное расписание, которое активирует ту или иную запись списка доступа. И сделать такой фокус, например, пишем список доступа, в котором запрещаем HTTP-доступ в течении рабочего дня и вешаем его на интерфейс маршрутизатора, то есть, сотрудники предприятия пришли на работу, им закрывается HTTP-доступ, рабочий день закончился, HTTP-доступ открывается, пожалуйста, если хотите – сидите в Интернете.

Настройка

Сами ACL создаются отдельно, то есть это просто некий список, который создается в глобальном конфигураторе, потом он присваивается к интерфейсу и только тогда он и начинает работать. Необходимо помнить некоторые моменты для того, чтобы правильно настроить списки доступа:

- обработка ведется строго в том порядке, в котором записаны условия;
- если пакет совпал с условием, дальше он не обрабатывается;
- в конце каждого списка доступа стоит неявный deny any (запретить всё);
- расширенные ACL нужно размещать как можно ближе к источнику, стандартные же как можно ближе к получателю;
- нельзя разместить более 1 списка доступа на интерфейс, на протокол, на направление;
- ACL не действует на трафик, сгенерированный самим маршрутизатором.
- Для фильтрации адресов используется WildCard маска

Стандартный список доступа

```
Router(config)#access-list <номер списка от 1 до 99> {permit | deny | remark} {address | any | host}[source-wildcard] [log]
```

- permit: разрешить
- deny: запретить
- remark: комментарий о списке доступа
- address: запрещаем или разрешаем сеть
- any: разрешаем или запрещаем всё
- host: разрешаем или запрещаем хосту
- source-wildcard: WildCard маска сети
- log: включаем логирование пакетов проходящие через данную запись ACL

Расширенный список доступа

Router(config)#**access-list** <номер списка от 100 до 199> {**permit** | **deny** | **remark**} protocol source [source-wildcard] [**operator** operand] [**port** <порт или название протокола> **established**]

- protocol source: какой протокол будем разрешать или закрывать (ICMP, TCP, UDP, IP, OSPF и т.д)
- deny: запретить
- operator: A.B.C.D — адрес получателя
- any — любой конечный хост
- eq — только пакеты на этом порте
- gt — только пакеты с большим номером порта
- host — единственный конечный хост
- lt — только пакеты с более низким номером порта
- neq — только пакеты не на данном номере порта
- range — диапазон портов
- port: номер порта (TCP или UDP), можно указать имя
- established: разрешаем прохождение TCP-сегментов, которые являются частью уже созданной TCP-сессии.

Прикрепляем к интерфейсу

Router(config-if)#**ip access-group** <номер списка или имя ACL> {**in** | **out**}

- **in**: входящее направление
- **out**: исходящее направление

Именованные списки доступа

Router(config)#**ip access-list** {**standard** | **extended**} {<номер ACL> | <имя ACL>}

Router(config-ext-nacl)# {**default** | **deny** | **exit** | **no** | **permit** | **remark**}

- **standard**: стандартный ACL
- **extended**: расширенный ACL
- **default**: установить команду в значение по умолчанию

Ограничение доступа к маршрутизатору

R(config)#**line vty** 0 4 — переходим в режим настройки виртуальных линий.

R(config-line)#**password** <пароль>

R(config-line)#**login**

R(config-line)#**access-class** 21 **in** — настраиваем логин и пароль, а также закрепляем список доступа с разрешенными IP-адресами.

Динамические списки доступа

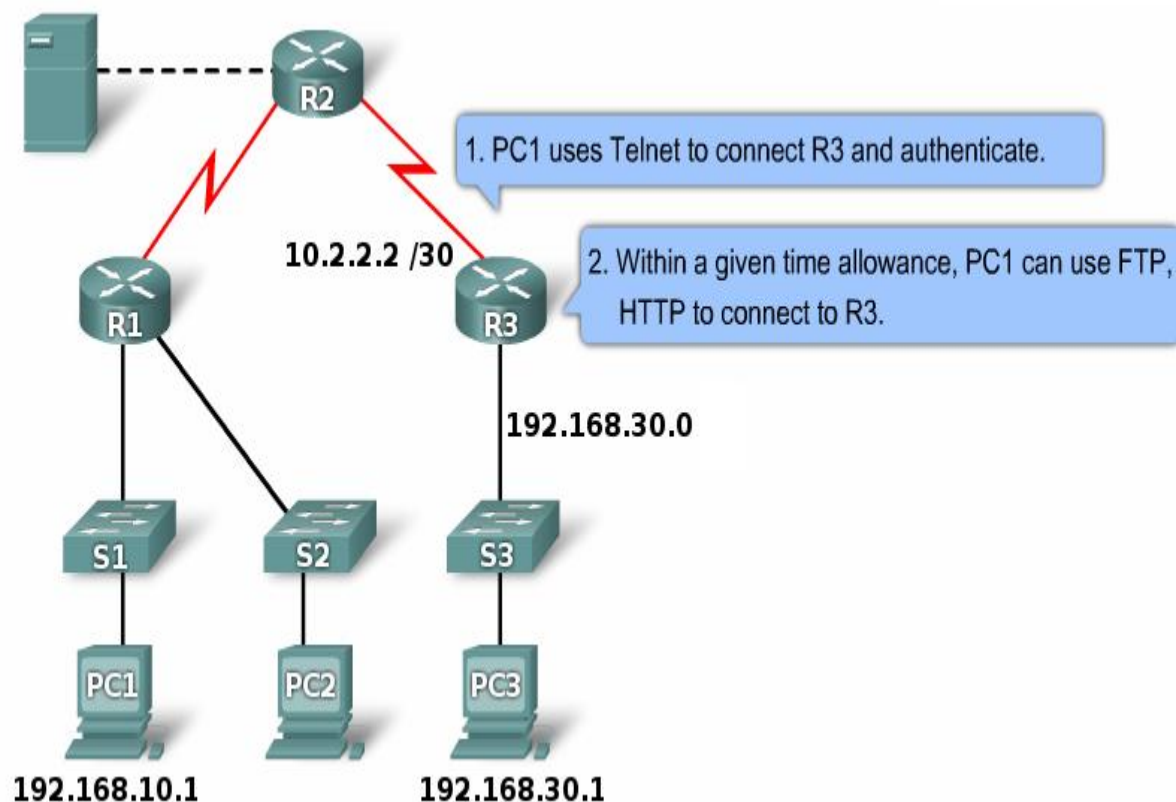


Рисунок 7

R3(config)#username Student password 0 cisco — создаем пользователей для подключения через Telnet.

R3(config)#access-list 101 permit tcp any host 10.2.2.2 eq telnet

R3(config)#access-list 101 dynamic testlist timeout 15 permit ip 192.168.10.0 0.0.0.255 192.168.30.0 0.0.0.255 — разрешаем подключаться к серверу по Telnet всем узлам.

R3(config)#interface serial 0/0/1

R3(config-if)#ip access-group 101 in — закрепляем 101 ACL за интерфейсом в входящем направлении.

R3(config)#line vty 0 4

R3(config-line)#login local

R3(config-line)#autocommand access-enable host timeout 5 — как только пользователь аутентифицируется, сеть 192.168.30.0 будет доступна, через 5 минут бездействия сеанс закроется.

Задание к практической работе

Перед началом выполнения практической работы необходимо ознакомиться с программой «Cisco Packet Tracer». «Packet Tracer» – это программа, эмулирующая сети передачи данных, выпускаемый фирмой Cisco Systems. Позволяет делать работоспособные модели сети, настраивать (командами Cisco IOS) маршрутизаторы и коммутаторы, взаимодействовать между несколькими пользователями (через облако). Включает в себя серии

маршрутизаторов Cisco 1800, 2600, 2800 и коммутаторов 2950, 2960, 3560.

1. Запустите программу «Packet Tracer» (Пуск => Все программы => папка «Cisco Packet Tracer» => «Cisco Packet Tracer»). В появившемся окне необходимо загрузить карту сети с настроенной маршрутизации, для этого нажмите на кнопку «File» => «Open...» (Рисунок 1 **Ошибка! Источник ссылки не найден.**)

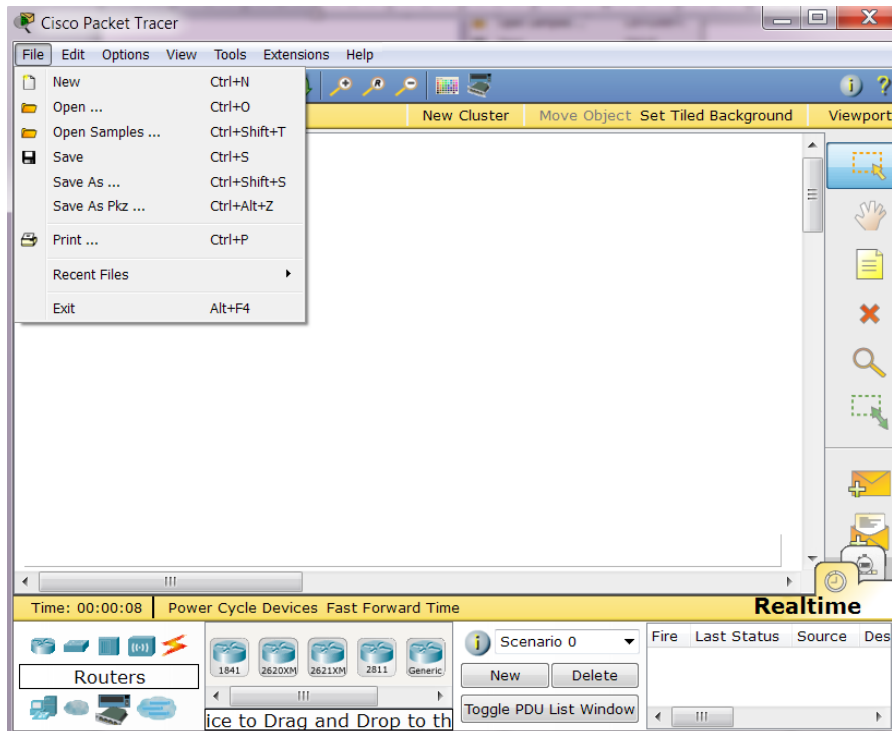


Рисунок 1

2. В открывшемся окне выберите файл Firewall_2_cisco.pkt и нажмите кнопку «Открыть» (Рисунок 2).

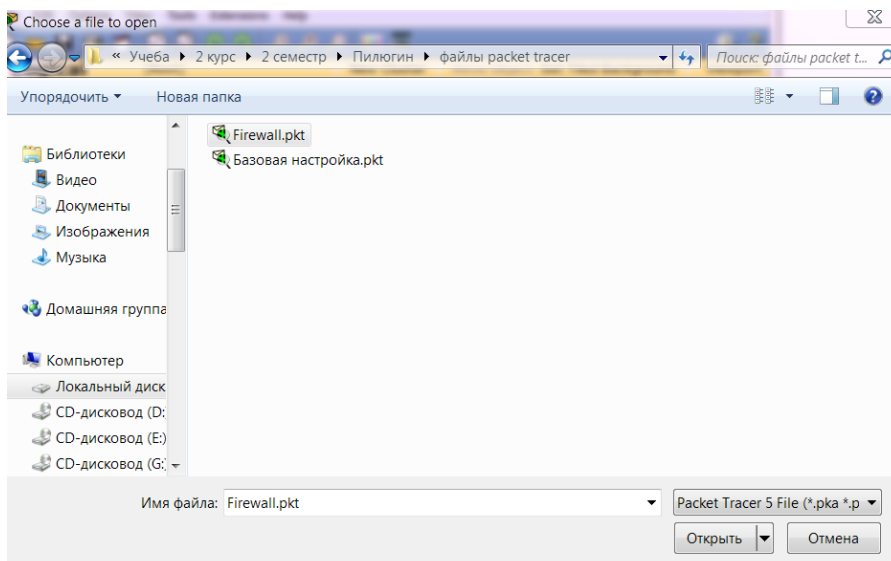


Рисунок 2

3. В появившемся окне отобразится топология сети, используемая в данной практической работе (Рисунок 3).

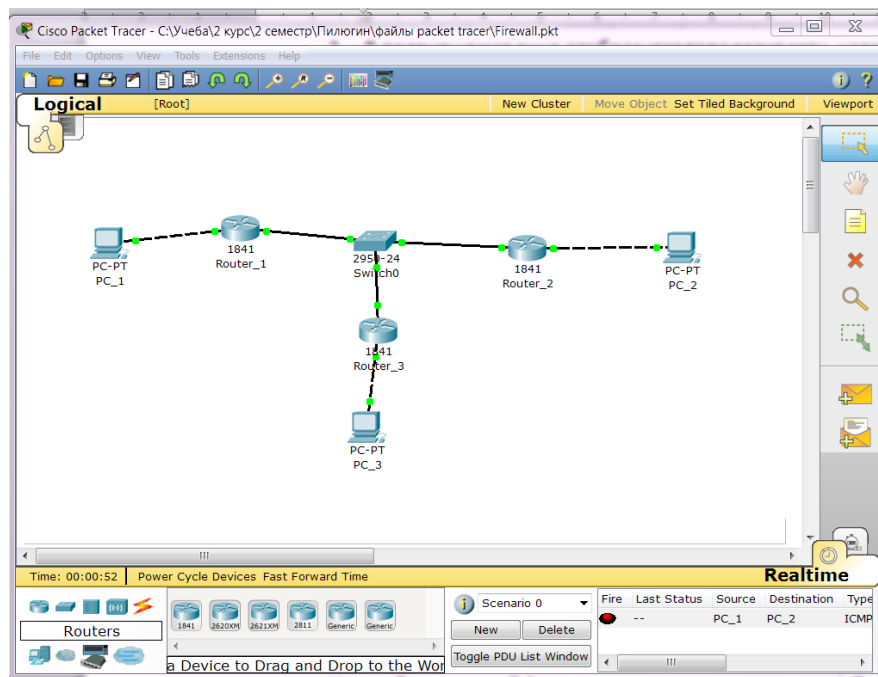


Рисунок 3

Настройка межсетевого экрана с функцией пакетной фильтрацией

В данной работе необходимо разрешить компьютеру из локальной сети LAN1 доступ к компьютеру PC_2, размещенному в локальной сети LAN2. Доступ компьютера PC_1 к PC_3, размещенному в локальной сети LAN3, запретить. Контроль прохождения трафика реализовать посредством использования функции пакетной фильтрации на маршрутизаторах. Логическая топология представлена на рисунке 4.

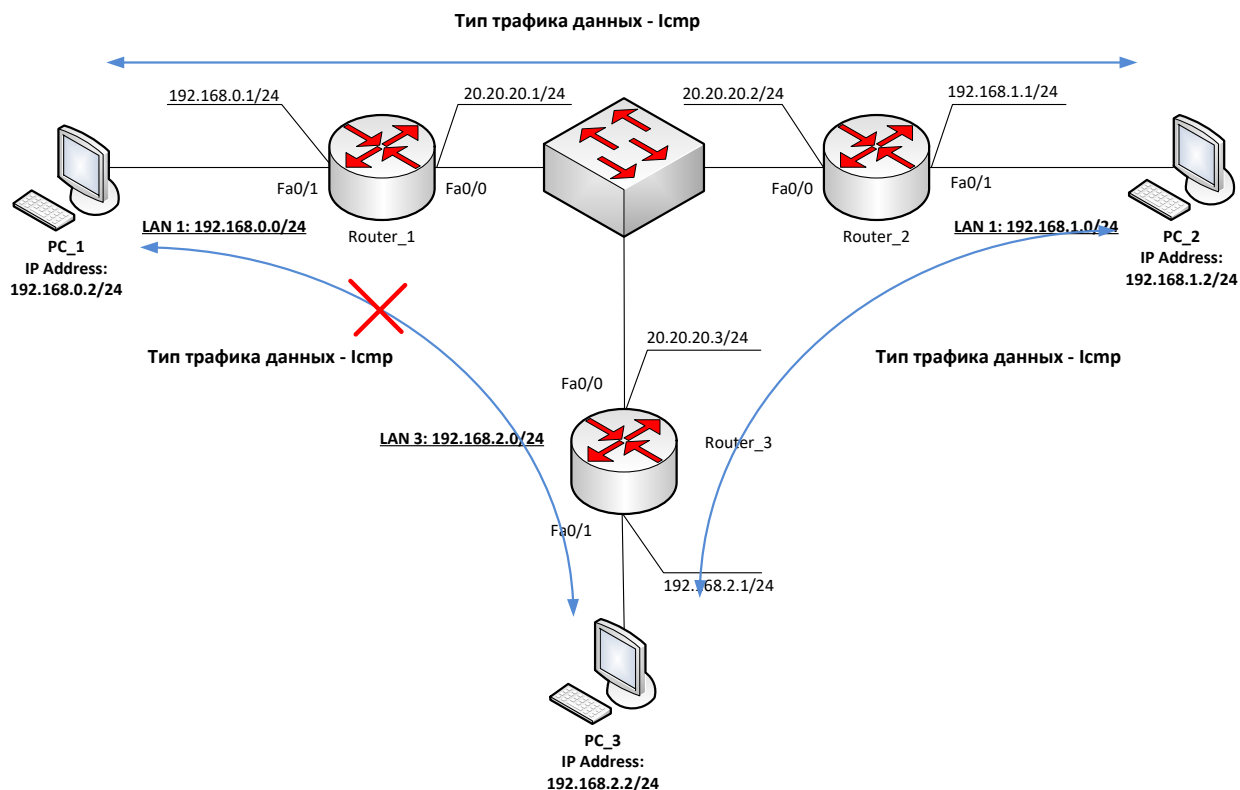


Рисунок 8

1. Настройте правила пакетной фильтрации на Router_1. Разрешите прохождение трафика из сети LAN 1 в сеть LAN 2 и обратно при помощи использования списков доступа, ACL.
2. Войдите в конфигурационный режим и создайте расширенный список доступа с названием «LIST»:

```
Router_1>en
Router_1#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router_1(config)#ip access-list extended LIST
```

3. Разрешите прохождения трафика между LAN1 и LAN2, добавив правило фильтраций в расширенный список доступа «LIST»:

```
Router_1(config-ext-nacl)#permit ip 192.168.0.0 0.0.0.255 192.168.1.0 0.0.0.255
```

4. Примените данное правило фильтрации на интерфейс fa0/1 для прохождения трафика данных. Направление трафика данных должно быть ориентировано на вход интерфейса fa 0/1:

```
Router_1(config)#interface fa0/1
Router_1(config-if)#ip access-group LIST in
Router_1(config-if)#exit
```

5. Настройте правила пакетной фильтрации на Router_2. Разрешите прохождение трафика из сети LAN 2 в сеть LAN 1 и обратно при помощи использования ACL.

6. Войдите в конфигурационный режим и создайте расширенный список доступа с названием «LIST»:

```
Router_2>en
Router_2#configure terminal
Enter configuration commands, one per line. End with CNTL/Z.
Router_2(config)#ip access-list extended LIST
```

7. Разрешите прохождения трафика между LAN1 и LAN2, добавив правило фильтрации в расширенный список доступа «LIST»:

```
Router_1(config-ext-nacl)#permit ip 192.168.1.0 0.0.0.255 192.168.0.0 0.0.0.255
```

8. Примените данное правило фильтрации на интерфейс fa0/1. Направление трафика данных должно быть ориентировано на вход интерфейса fa 0/1 в сторону LAN_1 или LAN_3:

```
Router_1(config)#interface fa0/1
Router_1(config-if)#ip access-group LIST in
Router_1(config-if)#exit
```

9. Запрещать доступ из LAN_2 в LAN_3 не требуется.

10. Настраивать маршрутизатор Router_3 не требуется.

11. Для проверки работоспособности решения иницилируйте соединение из сети LAN_1 в сеть LAN_2, введя команду ping до компьютера PC_2 на компьютере PC_1:

```
PC>ping 192.168.1.2
```

12. При успешной настройке маршрутизаторов соединение должно быть установлено. На экране монитора высвечивается следующий ответ на

сообщения:

```
PC>ping 192.168.1.2

Pinging 192.168.1.2 with 32 bytes of data:

Reply from 192.168.1.2: bytes=32 time=17ms TTL=126
Reply from 192.168.1.2: bytes=32 time=14ms TTL=126
Reply from 192.168.1.2: bytes=32 time=17ms TTL=126
Reply from 192.168.1.2: bytes=32 time=16ms TTL=126
```

13. Для проверки блокировки доступа из иницилируете соединение с компьютера PC_1 до компьютера PC_3, используя команду ping:

```
PC>ping 192.168.2.2
```

14. При успешной настройке маршрутизаторов и отработки правила блокировки трафика от сети LAN_1 до сети LAN_3 отобразятся следующие сообщения:

```
PC>ping 192.168.2.2

Pinging 192.168.2.2 with 32 bytes of data:

Reply from 192.168.0.1: Destination host unreachable.
Reply from 192.168.0.1: Destination host unreachable.
Reply from 192.168.0.1: Destination host unreachable.
Reply from 192.168.0.1: Destination host unreachable.

Ping statistics for 192.168.2.2:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss),
```

15. Для проверки возможности доступа из сети LAN_2 в сеть LAN_3, введя команду ping до компьютера PC_3 на компьютере PC_2:

```
PC>ping 192.168.2.2
```

16. При успешной настройке маршрутизаторов соединение должно быть установлено. На экране монитора высвечивается следующий ответ на сообщения:

```
PC>ping 192.168.2.2

Pinging 192.168.2.2 with 32 bytes of data:

Reply from 192.168.2.2: bytes=32 time=17ms TTL=126
Reply from 192.168.2.2: bytes=32 time=14ms TTL=126
Reply from 192.168.2.2: bytes=32 time=17ms TTL=126
Reply from 192.168.2.2: bytes=32 time=16ms TTL=126
```

17. Если вы получаете иной вывод команд при использовании утилиты ping стоит проверить правильность настроек маршрутизации, коммутации, ip адресов, правил фильтрации и направления списка доступа.

Настройка межсетевого экрана с функцией контроля состояния сессии

В данной работе необходимо разрешить компьютеру из локальной сети LAN1 только доступ к WEB ресурсам, размещенным на компьютере в локальной сети LAN_2, и прохождение трафика icmp (использование команды ping). Доступ до Web ресурсов контролируется настройками правил фильтрации и отслеживается при помощи функции контроля состояния http сессии. Остальной трафик данных из LAN_1 до LAN_2 и LAN_3 запретить. Так же необходимо запретить любой трафик данных, поступающий от сетей LAN_2 и LAN_3 до сети LAN_1. Схема стенда представлена на рисунке 5

Рисунок .

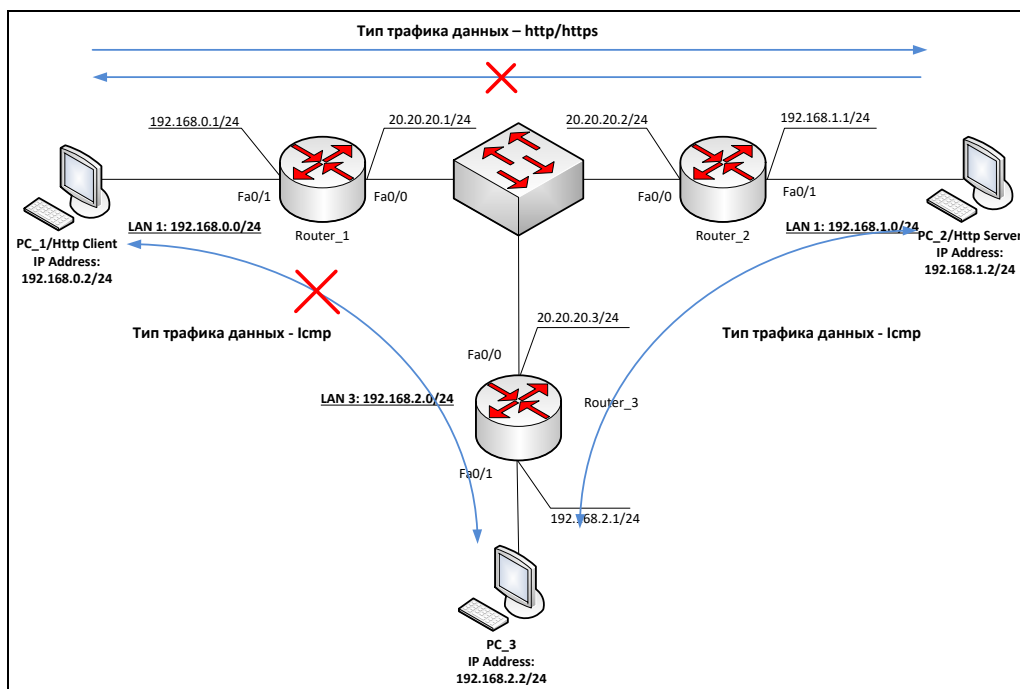


Рисунок 5

1. Откройте файл с заранее подготовленной топологией

firewall_2_cisco.ptk.

2. Настройте список доступа, который будет инспектировать TCP, UDP, ICMP, HTTP трафик и будет разрешать доступ только извне от PC_1 до HTTP сервера, выполнив команды ниже:

```
Router_1>en
Router_1#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router_1(config)#ip inspect name INSPECT tcp
Router_1(config)#ip inspect name INSPECT udp
Router_1(config)#ip inspect name INSPECT icmp
Router_1(config)#ip inspect name INSPECT http
Router_1(config)#ex
```

3. Примените созданный список доступа на интерфейс Fa 0/1 в направление движения трафика от PC_1 до HTTP сервера, то есть на IN:

```
Router_1#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router_1(config)#int fa 0/1
Router_1(config-if)#ip inspect INSPECT in
Router_1(config-if)#ex
Router_1(config)#ex
Router_1#
```

4. Запретите прохождение TCP, UDP и ICMP трафика извне до компьютера PC_1 при помощи использования списка доступа. Далее примените созданный список доступа на внешний интерфейс маршрутизатора, а именно fa 0/0 в направлении входа на этот интерфейс маршрутизатора:

```
Router_1#
Router_1#conf t
Enter configuration commands, one per line. End with CNTL/Z.
Router_1(config)#ip access-list LIST
Router_1(config-ext-nacl)#deny tcp any any
Router_1(config-ext-nacl)#deny udp any any
Router_1(config-ext-nacl)#deny icmp any any
Router_1(config-ext-nacl)#ex
Router_1(config)#int fa 0/0
Router_1(config-if)#ip access-group LIST in
Router_1(config-if)#ex
Router_1(config)#ex
Router_1#
```

5. Для проверки работоспособности стенда выполните команду с

HTTP сервера до PC_1. При правильной настройке трафик данных до PC_1 поступать не будет, т.к. отрабатывает список доступа, блокирующий трафик из вне («LIST»):

```
SERVER>ping 192.168.0.2

Pinging 192.168.0.2 with 32 bytes of data:

Request timed out.
Request timed out.
Request timed out.
Request timed out.

Ping statistics for 192.168.0.2:
    Packets: Sent = 4, Received = 0, Lost = 4 (100% loss)
```

6. Для того, чтобы компьютер PC_1 получил доступ к HTTP серверу, необходимо инициировать соединение из локальной сети LAN_1 до сети LAN_2, выполнив команду PING и написав адрес http сервера в WEB-браузере:

```
PC>ping 192.168.1.2

Pinging 192.168.1.2 with 32 bytes of data:

Reply from 192.168.1.2: bytes=32 time=16ms TTL=126
Reply from 192.168.1.2: bytes=32 time=15ms TTL=126
Reply from 192.168.1.2: bytes=32 time=15ms TTL=126
Reply from 192.168.1.2: bytes=32 time=18ms TTL=126

Ping statistics for 192.168.1.2:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 15ms, Maximum = 18ms, Average = 16ms

PC>
```

7. Для просмотра активных сессий, инициируйте соединение с компьютера PC_1 используя команду `ping -n`, где `n`- это количество отправляемых icmp пакетов. `N` должно быть не менее 50.

```
PC>ping 192.168.1.2 -100
```

8. Для просмотра информации об активных сессиях, о количестве отправленных пакетах и т.д. на маршрутизаторе Router_1 введите команду:

```
Router_1#show ip inspect sessions detail
```


Established Sessions

Session 286615208 (192.168.0.2:8)=>(192.168.1.2:0) icmp SIS_OPEN

Created 00:00:09, Last heard 00:00:09

ECHO request

Bytes sent (initiator:responder) [360:360]

In SID 192.168.1.2[0:0]=>192.168.0.2[0:0] on ACL LIST (10 matches)

9. Если вы получаете иной вывод команд при использовании утилиты ping или show ip inspect detail стоит проверить правильность настроек маршрутизации, коммутации, ip адресов, правил фильтрации и направления списка доступа.

Составьте отчет о выполнении практической работы.

Включите в него копии экрана пошагового выполнения работы и ответы на вопросы практической работы.